



Teknoloji Fakültesi

BİLGİSAYAR MÜHENDİSLİĞİ BÖLÜMÜ

BÜYÜK DİL MODELLERİ İLE GÜVENLİK AÇIĞI ANALİZİ ve GÜVENLİ KODLAMA: LORA TABANLI BİR YAKLAŞIM

BİTİRME PROJESİ

Bilgisayar Mühendisliği Bölümü

DANIŞMAN

Doç.Dr. Ayşe Berna ALTINEL GİRGİN

İSTANBUL, 2026

"



Teknoloji Fakültesi

BİLGİSAYAR MÜHENDİSLİĞİ BÖLÜMÜ

BÜYÜK DİL MODELLERİ İLE GÜVENLİK AÇIĞI ANALİZİ ve GÜVENLİ KODLAMA: LORA TABANLI BİR YAKLAŞIM

BİTİRME PROJESİ

Bilgisayar Mühendisliği Bölümü

DANIŞMAN

Doç.Dr. Ayşe Berna ALTINEL GİRGİN

İSTANBUL, 2026

"

MARMARA ÜNİVERSİTESİ
TEKNOLOJİ FAKÜLTESİ
BİLGİSAYAR MÜHENDİSLİĞİ BÖLÜMÜ

Marmara Üniversitesi Teknoloji Fakültesi Bilgisayar Mühendisliği Öğrencileri Ahmet Erdem Yabacı, Ali Mete Çıplak, Ertunga Yusuf Ocak, Fatih Eren Durmuş tarafından “Büyük Dil Modelleri ile Güvenlik Açığı Analizi ve Güvenli Kodlama: LoRA Tabanlı Bir Yaklaşım” başlıklı proje çalışması, 11.06.2026 tarihinde savunulmuş ve jüri üyeleri tarafından başarılı bulunmuştur.

Jüri Üyeleri

Doç. Dr. Ayşe Berna Altınel Girgin	(Danışman)	
Marmara Üniversitesi		(İMZA).....
Prof. Dr. Şahin Uyaver	(Üye)	
Marmara Üniversitesi		(İMZA).....
Dr. Öğr. Üyesi Neşe Özdemir	(Üye)	
Marmara Üniversitesi		(İMZA).....
Arş. Gör. Dr. Merve Pınar	(Üye)	
Marmara Üniversitesi		(İMZA).....

ÖNSÖZ

Proje çalışmamız süresince karşılaştığım bütün problemlerde, sabırla yardım ve bilgilerini esirgemeyen, tüm desteğini sonuna kadar yanımda hissettiğim değerli hocalarım, sayın Doç. Dr. Ayşe Berna Altınel Girgin ve sayın Prof. Dr. Şahin Uyaver'e en içten teşekkürlerimi sunarım.

Bu proje çalışması fikrinin oluşması ve ortaya çıkmasındaki önerisi ve desteğinden dolayı değerli hocam Doç. Dr. Ayşe Berna Altınel Girgin'e teşekkür ederim.

Proje çalışmam sırasında maddi ve manevi desteklerini esirgemeyen okul içerisinde ve okul dışında her zaman yanımda olan değerli çalışma arkadaşlarım ve hocalarım Doç. Dr. Ayşe Berna Altınel Girgin, Prof. Dr. Şahin Uyaver, Dr. Öğr. Üyesi Neşe Özdemir ve Arş. Gör. Dr. Merve Pınar'a sonsuz teşekkürlerimi sunarım.

İçindekiler

1. GİRİŞ	10
2. LİTERATÜR TARAMASI.....	11
3. VERİ SETİ	14
3.1. CodeSearchNet.....	15
3.2. BigVul	15
3.3. SecureCode-Web.....	15
3.4. Fenrir-v2.1	15
4. DEĞERLENDİRME METRİKLERİ	16
4.1. Sınıflandırma Tabanlı Metrikler	16
4.1.1 Doğruluk	16
4.1.2 Kesinlik.....	16
4.1.3 Duyarlılık.....	16
4.1.4 F1 Skoru.....	17
4.2. ROUGE Metrikleri.....	17
4.3. Semantik Benzerlik.....	17
5. YÖNTEM	18
6. SONUÇLAR.....	19
6.1. BigVul Deney Sonuçları	19
6.2. SecureCode-Web Deney Sonuçları.....	20
6.3. Fenrir-v2.1 Deney Sonuçları	21
6.4. Karşılaştırma.....	22
KAYNAKÇA.....	24

ÖZET

Büyük Dil Modelleri ile Güvenlik Açığı Analizi ve Güvenli Kodlama: LoRA Tabanlı Bir Yaklaşım

Büyük Dil Modelleri (Large Language Models - LLM), son yıllarda yazılım geliştirme süreçlerinde önemli başarılar elde etmiş ve kod üretme, kod açıklama, hata ayıklama ve dokümantasyon oluşturma gibi görevlerde yaygın olarak kullanılmaya başlanmıştır. Ancak genel amaçlı kodlama modelleri, güvenlik açıklarının tespiti, güvenli kodlama ilkelerinin uygulanması ve siber güvenlik odaklı akıl yürütme gibi alanlarda sınırlı performans göstermektedir. Bu durum, güvenlik açısından kritik yazılım sistemlerinde kullanılabilecek uzmanlaşmış modellerin geliştirilmesini gerekli kılmaktadır.

Bu çalışmada, Qwen 2.5 Coder 7B Instruct temel modeli, siber güvenlik alanına özgü görevlerde uzmanlaştırmak amacıyla Düşük Dereceli Uyarlama (Low-Rank Adaptation - LoRA) yöntemi kullanılarak ince ayar edilmiştir. Eğitim sürecinde modelin hem genel kod anlama yeteneğini koruması hem de güvenlik odaklı bilgi kazanması amacıyla dört farklı veri seti kullanılmıştır: CodeSearchNet, BigVul, SecureCode-Web ve Fenrir-v2.1. Bu veri kümeleri sırasıyla kod anlama ve dokümantasyon üretimi, güvenlik açığı farkındalığı, OWASP odaklı güvenli kod analizi ve siber güvenlik talimat takibi görevlerini kapsamaktadır.

Eğitim süreci sırasında 4-bit kuantizasyon, LoRA adaptörleri ve Unsloth optimizasyon çerçevesi kullanılarak parametre verimli bir ince ayar yaklaşımı uygulanmıştır. Model performansı doğruluk (Accuracy), kesinlik (Precision), duyarlılık (Recall), F1-Skoru, ROUGE ve semantik benzerlik metrikleri kullanılarak değerlendirilmiştir.

Deney sonuçları, önerilen yaklaşımın özellikle BigVul ve Fenrir-v2.1 veri setlerinde temel modele kıyasla önemli performans artışları sağladığını göstermektedir. Elde edilen bulgular, farklı karakteristiklere sahip siber güvenlik veri kümelerinin birlikte kullanılmasının, büyük dil modellerine güvenlik açığı farkındalığı kazandırmada ve güvenli kod analizi yeteneklerini geliştirmede etkili bir yöntem olduğunu ortaya koymaktadır.

Anahtar Kelimeler: Büyük Dil Modelleri, Siber Güvenlik, Güvenlik Açığı Tespiti,

LoRA, Qwen 2.5 Coder, Güvenli Kodlama, İnce Ayar

2026

Öğrenciler

**Ahmet Erdem Yabacı, Ali Mete Çıplak,
Ertunga Yusuf Ocak, Fatih Eren Durmuş**

ABSTRACT

Vulnerability Analysis and Secure Coding with Large Language Models: A LoRA-Based Approach

Large Language Models (LLMs) have recently achieved remarkable success in software engineering tasks such as code generation, code explanation, debugging, and documentation generation. However, general-purpose code models often demonstrate limited performance in vulnerability detection, secure coding practices, and cybersecurity-oriented reasoning. This limitation highlights the need for domain-adapted models specialized in cybersecurity applications.

In this study, the Qwen 2.5 Coder 7B Instruct model is fine-tuned using the Low-Rank Adaptation (LoRA) approach to enhance its cybersecurity expertise while preserving its general code understanding capabilities. Four complementary datasets are employed during training: CodeSearchNet, BigVul, SecureCode-Web, and Fenrir-v2.1. These datasets provide knowledge related to code understanding and documentation generation, vulnerability awareness, OWASP-oriented secure code analysis, and cybersecurity instruction-following tasks, respectively.

To achieve parameter-efficient adaptation, the training pipeline incorporates 4-bit quantization, LoRA adapters, and the Unsloth optimization framework. The performance of the fine-tuned model is evaluated using Accuracy, Precision, Recall, F1-Score, ROUGE metrics, and semantic similarity measures.

Experimental results demonstrate that the proposed approach significantly improves the model's performance, particularly on the BigVul and Fenrir-v2.1 evaluation datasets. The findings indicate that combining heterogeneous cybersecurity datasets is an effective strategy for enhancing vulnerability awareness, secure coding analysis, and cybersecurity reasoning capabilities in large language models.

Keywords: Large Language Models, Cybersecurity, Vulnerability Detection, LoRA, Qwen 2.5 Coder, Secure Coding, Fine-Tuning

2026

Students

Ahmet Erdem Yabacı, Ali Mete Çıplak,

Ertunga Yusuf Ocak, Fatih Eren Durmuş

KISALTMALAR

AI	: Artificial Intelligence (Yapay Zekâ)
NLP	: Natural Language Processing (Doğal Dil İşleme)
SQL	: Structured Query Language
XSS	: Cross-Site Scripting
CI/CD	: Continuous Integration / Continuous Deployment
LLM	: Large Language Model (Büyük Dil Modeli)
CWE	: Common Weakness Enumeration
CVE	: Common Vulnerabilities and Exposures
OWASP	: Open Web Application Security Project
LoRA	: Low-Rank Adaptation
CTI	: Cyber Threat Intelligence
MLM	: Masked Language Modeling
NER	: Named Entity Recognition
GNN	: Graph Neural Network
SAST	: Static Application Security Testing
VRAM	: Video Random Access Memory
LCS	: Longest Common Subsequence

TABLO LİSTESİ

Tablo 2.1 Literatür Taraması Özet Tablosu (2021-2025)	13
Tablo 3.1 Model eğitiminde kullanılan veri setleri ve özellikleri	14
Tablo 5.1 LoRA ayarları	18
Tablo 6.1 BigVul veri seti ile yapılan değerlendirmenin sonuçları	19
Tablo 6.2 SecureCode-Web veri seti ile yapılan değerlendirmenin sonuçları	20
Tablo 6.3 Fenrir-v2.1 veri seti ile yapılan değerlendirmenin sonuçları	21

1. GİRİŞ

LLM’lerdeki son gelişmeler, yazılım alanını büyük ölçüde değiştirmiştir. Kod anlama ve oluşturma alanında özelleşen modeller; kod oluşturma, hata düzeltme, kod özetleme ve doküman oluşturma alanlarında oldukça yüksek performans vermektedir. Bu gelişmelere rağmen, genel amaçlı modellerin çoğu özellikle siber güvenlik ve güvenlik açıklarıyla ilgili akıl yürütme görevlerinde sınırlı bir performans sergilemektedir.

LLM’lerle ilgili en büyük endişelerden birisi kod oluşturma sırasında zafiyetli kod kalıpları kullanmaları ve zafiyetleri tespit edememeleridir. Güvenlik açısından kritik yazılım sistemleri, yalnızca sözdizimsel doğruluğa sahip değil, aynı zamanda güvenli kodlama ilkelerini, zafiyet türlerini, saldırı yüzeylerini ve azaltma stratejilerini de anlayabilen modellere ihtiyaç duymaktadır. Mevcut temel kodlama modelleri genellikle güvensiz veya zafiyet içeren uygulamalar barındırabilen, büyük ölçekli internet kod depoları üzerinde eğitilmektedir.

Bu sınırlılığı gidermek amacıyla bu çalışma; güvenli kodlama, zafiyet analizi, kodlama anlayışı ve siber güvenlik talimat takibi görevlerini kapsayan birden fazla özelleştirilmiş veri setini kullanarak, Qwen 2.5 Coder 7B Instruct modeli için siber güvenlik odaklı bir ince ayar iş hattı önermektedir. Önerilen sistem, birbirini tamamlayıcı nitelikteki dört veri kümesini bir araya getirmektedir:

- Python kodunun anlaşılması ve dokümantasyon üretimi için CodeSearchNet,
- Zafiyet sınıflandırması ve zafiyet farkındalıklı öğrenme için BigVul,
- OWASP odaklı güvenli kodlama analizi için SecureCode-Web,
- Siber güvenlik talimat uyarlaması ve alana özgü diyalogsal öğrenme için Fenrir-v2.1.

Bu çalışma, hesaplama açısından maliyetli olan tam ince ayar yapmak yerine, 4-bit kuantizasyon ile birlikte Düşük Dereceli Uyarlama (LoRA) tekniğini benimsemektedir. Bu parametre verimli eğitim stratejisi, temel modelin çekirdek muhakeme yeteneklerini korurken donanım gereksinimlerini önemli ölçüde azaltmaktadır. Eğitim süreci, Unsloth optimizasyon çerçevesi ve AdamW 8-bit optimizasyonu kullanılarak gerçekleştirilmiştir.

Bu çalışmanın temel katkıları şu şekilde özetlenmektedir:

1. Kod odaklı modern bir LLM için alana özgü bir siber güvenlik ince ayar iş hattının geliştirilmesi.
2. Çeşitli heterojen siber güvenlik veri kümelerinin birleşik bir talimat uyarlama iş akışına

entegre edilmesi.

3. Ölçeklenebilir siber güvenlik uyarlaması için 4-bit kuantizasyon ile parametre verimli LoRA ince ayarının uygulanması.
4. Zafiyet odaklı muhakeme ve güvenli kodlama analizi yapabilen, siber güvenlik farkındalığına sahip bir kodlama asistanının oluşturulması.

2. LİTERATÜR TARAMASI

LLM'lerin yazılım geliştirme süreçleri ile yaygınlaşması üzerine bu modellerin güvenlik açıklarını tespit edebilmesi, güvenli kod üretebilmesi ve siber güvenlik alanında yeterliliğe sahip olması büyük bir öneme sahiptir. Bu alandaki araştırmalar özellikle modellerin güvenlik açıklarını tespit etmeye odaklanmıştır.

Bu alandaki önemli çalışmalardan biri olan Chen vd. (2023) tarafından geliştirilen DiverseVul veri seti, derin öğrenme tabanlı güvenlik açığı tespit sistemleri için oluşturulmuş en kapsamlı veri kümelerinden biridir [1]. Çalışmada farklı CWE kategorilerine ait yüz binlerce güvenlik açığı örneği kullanılarak CodeBERT, RoBERTa ve Graph Neural Network tabanlı modeller karşılaştırılmıştır. Sonuçlar, transformer tabanlı modellerin zafiyet tespitinde geleneksel yöntemlere göre daha yüksek performans gösterebildiğini ortaya koymuştur.

Kod güvenliği alanında büyük dil modellerinin gerçek performansını değerlendiren CASTLE Benchmark çalışmasında Dubniczky vd. (2025), çeşitli LLM'leri CWE tabanlı güvenlik açığı tespiti görevlerinde incelemiştir [2]. Araştırma sonuçları, modellerin küçük ve izole kod parçalarında başarılı olduğunu ancak kod karmaşıklığı arttıkça yanlış pozitif ve yanlış negatif oranlarının yükseldiğini göstermiştir. Bu çalışma, LLM tabanlı güvenlik sistemlerinde veri kümesi çeşitliliğinin ve görev odaklı ince ayarın önemini vurgulamaktadır.

Pearce vd. (2022), GitHub Copilot tarafından üretilen kodların güvenlik açısından değerlendirilmesini gerçekleştirmiştir [3]. Araştırmada Copilot'un bazı senaryolarda güvenli kod üretebildiği ancak önemli bir kısmında güvenlik açığı içeren kod parçaları oluşturduğu gözlemlenmiştir. Çalışma, genel amaçlı kod modellerinin güvenlik odaklı veri setleriyle desteklenmeden kritik yazılım geliştirme süreçlerinde kullanılmasının risk oluşturabileceğini göstermektedir.

Fu ve Tantithamthavorn (2022), önceden eğitilmiş kod modellerinin güvenlik açığı tespit görevlerinde kullanılabilirliğini incelemiştir [4]. Çalışmada CodeBERT ve GraphCodeBERT modelleri BigVul veri seti üzerinde değerlendirilmiş ve ön eğitim sürecinde öğrenilen semantik

kod bilgisinin güvenlik açıklarının belirlenmesinde önemli katkı sağladığı ortaya konmuştur. Özellikle BigVul veri seti üzerinde yapılan deneyler, transformer tabanlı modellerin geleneksel statik analiz yöntemleriyle rekabet edebilecek seviyeye ulaştığını göstermiştir.

Aghaei vd. (2022) tarafından geliştirilen SecureBERT, siber güvenlik alanına özgü metinleri anlamak için tasarlanmış alan-özelleştirilmiş bir dil modelidir [5]. Çalışmada siber tehdit istihbaratı (Cyber Threat Intelligence - CTI) verileri ve diğer güvenlik odaklı metinlerden oluşan geniş bir derlem kullanılarak BERT tabanlı model yeniden eğitilmiştir. Araştırmacılar, güvenlik terminolojisini daha iyi temsil edebilmek amacıyla özel bir tokenizer geliştirmiş ve önceden eğitilmiş ağırlıkları alan bilgisine uyarlamıştır. Deneysel sonuçlar, SecureBERT'in Masked Language Modeling (MLM), adlandırılmış varlık tanıma (NER) ve diğer siber güvenlik odaklı NLP görevlerinde genel amaçlı dil modellerine kıyasla daha yüksek başarı elde ettiğini göstermiştir. Çalışma, alan-özelleştirilmiş dil modellerinin siber güvenlik uygulamalarında tehdit analizi ve otomatik bilgi çıkarımı gibi görevlerde önemli performans avantajları sağlayabileceğini ortaya koymuştur.

Güncel çalışmalarda dikkat çeken bir diğer konu ise parametre verimli ince ayar yöntemleridir. Hu vd. (2021) tarafından önerilen LoRA (Low-Rank Adaptation) yöntemi, büyük modellerin tamamını yeniden eğitmek yerine yalnızca küçük adaptasyon katmanlarının eğitilmesini mümkün kılmaktadır [6]. Bu yaklaşım, hesaplama maliyetini önemli ölçüde azaltırken model performansını koruyabilmektedir. Son yıllarda birçok siber güvenlik odaklı LLM çalışmasında LoRA ve kuantizasyon teknikleri yaygın olarak kullanılmaktadır.

Literatürdeki çalışmalar incelendiğinde, güvenlik açığı tespiti ve güvenli kod analizi alanında transformer tabanlı modellerin başarılı sonuçlar verdiği görülmektedir. Ancak mevcut çalışmaların büyük bölümü tek bir veri setine veya belirli bir güvenlik görevine odaklanmaktadır. Bu çalışmada ise CodeSearchNet, BigVul, SecureCode-Web ve Fenrir-v2.1 veri kümeleri birlikte kullanılarak hem kod anlama hem de güvenlik odaklı akıl yürütme yeteneklerine sahip bir model geliştirilmesi amaçlanmaktadır. Böylece modelin yalnızca zafiyet tespit etmesi değil, aynı zamanda güvenli kodlama önerileri sunabilmesi ve siber güvenlik alanındaki talimatları takip edebilmesi hedeflenmektedir.

Tüm bu teknik ve mimari gelişmelerin gerçek dünya senaryolarında sürdürülebilir olması ise modellerin eğitildiği verinin kalitesine ve dış müdahalelere karşı kararlılığına bağlıdır. Alghawazi vd. (2022) tarafından gerçekleştirilen sistematik derleme çalışmasında, web güvenliğinde derin öğrenme kullanımının sıklığı ve verimliliği tartışılırken, modellerin başarısındaki en kritik payın veri seti çeşitliliği olduğu vurgulanmıştır [7]. Aynı çalışmada,

literatürde özellikle yapay zekayı yanıltmaya yönelik tasarlanan aldatıcı örneklerle karşı modellerin savunulması konusundaki araştırmaların yetersiz kaldığına dikkat çekilmiştir. Sonuç olarak literatürdeki güncel eğilimler; geliştirilecek yeni nesil web güvenlik sistemlerinde hem veri seti çeşitlendirmenin hem de modellerin manipüle edilmiş saldırı varyasyonlarına karşı dayanıklılığının artırılmasının akademik ve pratik bir zorunluluk olduğunu göstermektedir.

He ve Vechev (2023) tarafından önerilen SVEN yaklaşımı, büyük dil modellerinin ürettiği kodun güvenlik seviyesini kontrol etmeyi amaçlamaktadır [8]. Çalışmada güvenli kod üretimini artırmak ve modelleri güvenlik açısından test etmek için özellik-odaklı yönlendirme vektörleri kullanılmıştır. Deney sonuçları, yöntemin kodun işlevselliğini korurken güvenli kod üretim oranını önemli ölçüde yükseltebildiğini göstermiştir. Bu çalışma, LLM tabanlı yazılım geliştirme araçlarında güvenlik odaklı kontrol mekanizmalarının uygulanabilir olduğunu ortaya koymuştur.

Tablo 2.1 Literatür Taraması Özet Tablosu (2021-2025)

<i>Kaynak / Yazar</i>	<i>Yıl</i>	<i>Yöntem</i>	<i>Temel Bulgular</i>
<i>Chen vd. – DiverseVul</i>	2023	Transformer ve GNN karşılaştırması	Büyük ölçekli zafiyet veri seti; model başarımı veri çeşitliliğine bağlı
<i>Dubniczky vd. – CASTLE</i>	2025	LLM + CWE Benchmark	Küçük kodlarda başarılı, büyük kodlarda hata oranı artıyor
<i>Pearce vd.</i>	2022	GitHub Copilot Güvenlik Analizi	Üretilen kodların önemli kısmı güvenlik açığı içerebiliyor
<i>Fu & Tantithamthavorn</i>	2022	CodeBERT, GraphCodeBERT + BigVul	Önceden eğitilmiş kod modelleri zafiyet tespitinde etkili
<i>Aghaei vd.</i>	2022	Siber güvenlik verileriyle eğitilmiş BERT modeli (SecureBERT)	Genel amaçlı BERT modellerinden daha yüksek başarı göstermiş, siber güvenlik görevlerinde performansı artırmıştır.
<i>Hu vd. (LoRA)</i>	2021	Parametre Verimli İnce Ayar	Düşük maliyetle yüksek performanslı model uyarlaması sağlıyor

2023	SVEN adı verilen kontrollü kod üretim yöntemi ve LLM yönlendirme vektörleri	LLM'lerin daha güvenli veya daha güvensiz kod üretmesi kontrol edilebilmiş; güvenli kod üretim oranı önemli ölçüde artırılırken işlevsel doğruluk korunmuştur.
------	---	--

3. VERİ SETİ

Bu çalışmada dört farklı veri seti kullanılarak Qwen 2.5 Coder 7B Instruct modelini siber güvenlik odaklı bir model oluşturmak hedeflenmiştir.

Geliştirilen siber güvenlik modelinin hem teorik siber güvenlik kavramlarını anlaması hem de işletim sistemi ve web seviyesindeki açıkları tespit edebilmesi için heterojen bir veri havuzu oluşturulmuştur. Bu mimaride, modelin spesifik zafiyetlere aşırı odaklanıp kodun genel çalışma mantığını unutmasını engellemek amacıyla temiz/referans kod verileri de eğitim sürecine dahil edilmiştir.

Tablo 3.1'de eğitim sürecine dahil edilen veri setlerinin teknik detayları ve çalışmaya sağladıkları özgün katkılar özetlenmiştir

Tablo 3.1 Model eğitiminde kullanılan veri setleri ve özellikleri

Veri Seti	Odak Alanı	Veri Tipi	Temel İçerik	Veri Hacmi (Örnek Sayısı)	Akademik Katkı
CodeSearchNet	Semantik Kod Anlayışı ve Referans Model	Sadece Python Fonksiyonları ve Docstring'ler	Temiz Python fonksiyonları, doğal dil açıklamaları.	412.178	Modelin zafiyetleri tespit edebilmesi için gerekli olan sağlıklı kod referansını oluşturur; kod-metin eşleşimini güçlendirir.
BigVul	Sistem Seviyesi ve CVE Analizi	Gerçek Dünya C/C++ Fonksiyonları	Bellek taşması, CWE eşleştirmeli sistem açıkları.	2.037	Literatürde belgelenmiş gerçek dünya saldırılarına karşı low-level denetim sağlar.
Securecode-Web	Web Kod Analizi (SAST)	Kod Parçacıkları (Güvenli/Zafiyetli)	Web zafiyetleri, JavaScript, Python, PHP.	1.102	Yüksek seviyeli dillerdeki hatalı yapıları tespit etme ve yama önerme yetisini geliştirir.

Fenrir-V2.1	Genel Siber Güvenlik	Alpaca / ChatML	Tehdit analizi, zafiyet tanımları, saldırı senaryoları.	99.870	Modelin kavramsal akıl yürütme yeteneğine hakim olmasını sağlar.
--------------------	----------------------	-----------------	---	--------	--

3.1. CodeSearchNet

Python kodunun anlaşılması ve dokümantasyon üretimi yeteneklerini geliştirmek amacıyla CodeSearchNet veri kümesi kullanılmıştır. Eğitim için yalnızca Python ile ilgili örnekler seçilmiştir. Toplam 412.178 örnek içeren bu veri kümesi, kaynak kod fonksiyonlarına yönelik doğal dil açıklamaları üretmeye odaklanmaktadır.

Eğitim formatı, sohbet şablonları aracılığıyla talimat takibi tabanlı bir diyalog yapısına dönüştürülmüştür. Model, verilen Python kod parçacıklarının işlevselliğini açıklamak üzere eğitilmiştir.

3.2. BigVul

Zafiyet odaklı öğrenme ve zafiyet sınıflandırması görevleri için BigVul veri kümesi kullanılmıştır. Eğitim sürecinde toplam 2.037 örnekten yararlanılmıştır. Veri kümesi; zafiyet barındıran ve barındırmayan kod örneklerinin yanı sıra, CVE ve CWE eşlemelerini de içeren zafiyet bağlantılı bilgileri barındırmaktadır. Eğitim hedefi, modelin yazılım zafiyetleri ve güvensiz kodlama örüntülerine yönelik anlayışını geliştirmeye odaklanmıştır.

3.3. SecureCode-Web

SecureCode-Web veri kümesi, OWASP İlk 10 güvenlik ilkeleriyle uyumlu güvenli kodlama diyaloglarını ve zafiyet analizi örneklerini içermektedir. Eğitim esnasında toplam 1.102 örnek kullanılmıştır. Kıdemli bir uygulama güvenliği mühendisini simüle etmek amacıyla eğitim iş hattı özel bir sistem promptu entegre edilmiştir. Diyalog yapılarını tek tip kullanıcı-asistan etkileşimlerine standartlaştırmak için rol normalizasyonu uygulanmıştır.

3.4. Fenrir-v2.1

Fenrir-v2.1 veri kümesi, 99.870 örnek içeren siber güvenlik odaklı bir diyalogsal talimat veri kümesidir. Veri kümesi; güvenlik analizi görevlerini, sızma testi tartışmalarını, exploit açıklamalarını ve siber güvenlik rehberliği diyaloglarını kapsamaktadır.

Veri kümesi; sistem, kullanıcı ve asistan rollerinden oluşan, ChatML uyumlu bir yapıya dönüştürülmüştür. Öğrenme sürecini kullanıcı komut istemleri yerine asistan çıktılarına odaklamak amacıyla, Unsloth çerçevesi kullanılarak yalnızca yanıtı dayalı kayıp optimizasyonu (response-only loss optimization) uygulanmıştır.

4. DEĞERLENDİRME METRİKLERİ

Model performansını değerlendirmek amacıyla sınıflandırma tabanlı, metin benzerliği tabanlı ve anlamsal benzerlik tabanlı çeşitli değerlendirme metrikleri kullanılmıştır. Bu metrikler sayesinde modelin hem güvenlik odaklı içerikleri üretme başarısı hem de üretilen cevapların referans metinlere olan benzerliği analiz edilmiştir.

4.1. Sınıflandırma Tabanlı Metrikler

Model çıktılarının güvenlik odaklı içerikleri ne ölçüde doğru ürettiğini belirlemek amacıyla doğruluk (accuracy), kesinlik (precision), duyarlılık (recall) ve F1 skoru kullanılmıştır. Bu değerlendirme sürecinde, model tarafından üretilen cevaplar ve gerçek cevaplar içerisinde belirli güvenlik anahtar kelimelerinin (*vulnerability*, *CVE*, *injection*, *XSS*, *OWASP*, *exploit*, *patch* ve *secure*) bulunup bulunmamasına göre ikili sınıflandırma gerçekleştirilmiştir.

4.1.1 Doğruluk

Doğruluk metriği, modelin toplam tahminler içerisindeki doğru tahmin oranını ifade etmektedir. Aşağıdaki denklemde gösterildiği şekilde hesaplanmaktadır:

$$\text{Doğruluk} = \frac{TP + TN}{TP + TN + FP + FN}$$

Burada:

- TP (True Positive): Doğru pozitif tahmin sayısı
- TN (True Negative): Doğru negatif tahmin sayısı
- FP (False Positive): Yanlış pozitif tahmin sayısı
- FN (False Negative): Yanlış negatif tahmin sayısıdır.

4.1.2 Kesinlik

Kesinlik metriği, model tarafından güvenlik odaklı olarak tahmin edilen örneklerin ne kadarının gerçekten güvenlik içeriği olduğunu göstermektedir. Aşağıdaki denklemde verilmiştir:

$$\text{Kesinlik} = \frac{TP}{TP + FP}$$

Yüksek precision değeri, modelin yanlış alarm üretme oranının düşük olduğunu göstermektedir.

4.1.3 Duyarlılık

Duyarlılık metriği, gerçek güvenlik içeriklerinin model tarafından ne ölçüde doğru tespit edildiğini ifade etmektedir. Aşağıdaki denklemde gösterilmektedir:

$$Duyarlılık = \frac{TP}{TP + FN}$$

Yüksek duyarlılık değeri, modelin güvenlik açıklarını kaçırma oranının düşük olduğunu göstermektedir.

4.1.4 F1 Skoru

F1 skoru, kesinlik ve duyarlılık değerlerinin harmonik ortalamasını alarak dengeli bir performans ölçümü sağlamaktadır. Özellikle veri dağılımının dengesiz olduğu durumlarda yaygın olarak kullanılmaktadır. Aşağıdaki denklemde verilmiştir:

$$F1 = 2 \times \frac{Kesinlik \times Duyarlilik}{Kesinlik + Duyarlilik}$$

4.2. ROUGE Metrikleri

Metin üretim performansını değerlendirmek amacıyla ROUGE-1 ve ROUGE-L metrikleri kullanılmıştır.

ROUGE-1, model çıktıları ile referans cevaplar arasındaki unigram örtüşmesini ölçmektedir.

ROUGE-L, en uzun ortak alt diziye (Longest Common Subsequence – LCS) dayalı olarak cümle yapısal benzerliğini değerlendirmektedir.

ROUGE-1 metriği aşağıdaki şekilde hesaplanmaktadır:

$$ROUGE-1 = \frac{Ortak\ unigram\ sayısı}{Referans\ metindeki\ toplam\ unigram\ sayısı}$$

ROUGE-L metriği ise en uzun ortak alt dizi uzunluğuna dayalı olarak hesaplanmaktadır:

$$ROUGE-L = \frac{LCS(X,Y)}{\max(|X|,|Y|)}$$

Burada LCS(X, Y), iki metin arasındaki en uzun ortak alt diziyi ifade etmektedir.

4.3. Semantik Benzerlik

Model çıktılarının referans cevaplarla anlamsal açıdan ne kadar benzer olduğunu ölçmek amacıyla semantik benzerlik metriği kullanılmıştır. Bu işlem için SentenceTransformers kütüphanesindeki all-MiniLM-L6-v2 modeli kullanılmıştır.

Öncelikle model çıktıları ve gerçek cevaplar vektör temsillerine dönüştürülmüş, ardından her çıktı-referans çifti arasındaki kosinüs benzerliği hesaplanmıştır. Kullanılan kosinüs benzerliği

formülü aşağıdaki denklemde verilmiştir:

$$\text{CosineSimilarity}(A, B) = \frac{A \cdot B}{\|A\| \|B\|}$$

Burada A ve B, metinlerin vektörel temsillerini ifade etmektedir. Elde edilen skorun 1'e yaklaşması, model çıktılarının anlamsal açıdan referans metinlere daha yakın olduğunu göstermektedir.

5. YÖNTEM

Önerilen yöntem, Qwen 2.5 Coder 7B Instruct modelinin LoRA kullanılarak verimli bir şekilde ince ayar edilmesidir.

Tablo 5.1'de kullanılan LoRA ayarları verilmiştir.

Tablo 5.1 LoRA ayarları

Parametre	Değer
LoRA Mertebesi (r)	16
LoRA Alfa Çarpanı	32
Kuantizasyon	4-bit
Optimizasyon Algoritması	AdamW 8-bit
Öğrenme Oranı Planlayıcısı	Linear

LoRA adaptörleri, aşağıdaki transformer katmanlarına uygulanmıştır:

- **q_proj** (Query Projection): Giriş temsilini “query” vektörüne dönüştürür. Attention mekanizmasında modelin hangi bilgilere odaklanacağını belirlemede kullanılır.
- **k_proj** (Key Projection): Giriş temsilini “key” vektörüne dönüştürür. Query vektörleriyle karşılaştırılarak hangi tokenların ilişkili olduğu hesaplanır.
- **v_proj** (Value Projection): Giriş temsilini “value” vektörüne dönüştürür. Attention sonucunda modele taşınan gerçek bilgi içeriğini temsil eder.
- **o_proj** (Output Projection): Attention katmanından çıkan bilgiyi yeniden modelin gizli boyutuna projekte eder ve sonraki katmanlara aktarır.
- **gate_proj** (Gate Projection): Feed-forward ağındaki kapı (gating) mekanizmasını oluşturur. Hangi bilginin daha fazla aktarılacağını kontrol ederek öğrenme kapasitesini artırır.
- **up_proj** (Up Projection): Gizli temsil boyutunu daha yüksek bir ara boyuta genişletir.

Feed-forward katmanında daha zengin özellik öğrenimi sağlar.

- **down_proj** (Down Projection): Genişletilmiş ara temsili tekrar modelin orijinal boyutuna indirger. Böylece işlenen bilgi sonraki katmanlara uygun boyutta aktarılır.

VRAM kullanımını azaltmak ve ince ayar sürecini hızlandırmak için eğitim sırasında Unsloth kütüphanesi kullanılmıştır. Veri setlerinde sohbet şablonları uygulanarak modellerin sohbet yetenekleri ve talimatlara uyma davranışlarının korunması hedeflenmiştir.

Seçilen veri setlerinde, maskelenmiş kayıp hesaplaması yöntemiyle sadece yanıt odaklı optimizasyon stratejileri uygulanmıştır. Bu yaklaşım, modelin kullanıcı girdilerini doğrudan öğrenmesinin önüne geçerek optimizasyonu asistan tarafından üretilen çıktılar üzerinde yoğunlaştırmaktadır.

Eğitim sürecinin temel amacı; güvenli kod anlama, zafiyet bilinciyle akıl yürütme ve OWASP odaklı güvenlik analizi yapabilen; siber güvenlik talimatlarına uyma, güvenlik odaklı kod açıklama ve üretme yetkinliklerine sahip, siber güvenlik alanında uzmanlaşmış bir kodlama asistanı oluşturmaktır.

6. SONUÇLAR

Bu kısımda, Qwen 2.5 Coder 7B Instruct temel modeli ile siber güvenlik odaklı veri setleri ile ince ayar yapılmış halinin performans karşılaştırılması yapılmıştır. Değerlendirme zafiyet anlama, güvenli kod analizi ve siber güvenlik talimat uyumu performansına odaklanmaktadır. Değerlendirme metriklerini olarak doğruluk, kesinlik, duyarlılık, F1-Skoru, ROUGE ve semantik benzerlik metrikleri kullanılmıştır.

6.1. BigVul Deney Sonuçları

BigVul veri seti ile yapılan deneylerde modelin yüksek zafiyet anlama ve sınıflandırma yetenekleri gözlenmiştir. Tablo 6.1’de temel model ve ince ayarlı model sonuçları gösterilmektedir.

Tablo 6.1 BigVul veri seti ile yapılan değerlendirmenin sonuçları

Metrik	Temel Model	İnce Ayarlı Model	Değişim
<i>Doğruluk</i>	0.6667	0.9362	+40.4%
<i>F1-Skor</i>	0.0000	0.9024	+0.9024
<i>Kesinlik</i>	0.0000	0.9204	+0.9204
<i>Duyarlılık</i>	0.0000	0.8851	+0.8851

<i>ROUGE-1</i>	0.0763	0.9433	+1136%
<i>ROUGE-L</i>	0.0727	0.9432	+1197%
<i>Semantik Benzerlik</i>	0.3836	0.9713	+153.2%

Sonuçlar, ince ayar işleminin BigVul veri seti üzerinde son derece önemli bir performans artışı sağladığını göstermektedir. Temel modelin F1-Skoru, kesinlik ve duyarlılık değerlerinin sıfır olması, modelin güvenlik açıklarını güvenilir biçimde tespit etmekte başarısız olduğunu göstermektedir. Buna karşın ince ayarlı model tüm sınıflandırma metriklerinde yüksek başarı elde etmiştir.

BigVul veri setinde gözlenen yüksek performans artışının temel nedeni, veri setinin doğrudan güvenlik açığı sınıflandırma görevine odaklanmasıdır. Eğitim sürecinde kullanılan örnekler, modelin CVE ve CWE ilişkilerini öğrenmesine, bellek taşması, kullanım sonrası serbest bırakma (use-after-free) ve tampon taşması gibi yaygın güvenlik açıklarını tanımasına olanak sağlamıştır. Temel model genel kod üretme ve anlama yeteneklerine sahip olmasına rağmen güvenlik odaklı örüntüleri ayırt etmekte yetersiz kalmıştır. LoRA ince ayarı sonrasında model, güvenlik açıkları ile ilişkili semantik kalıpları daha etkin şekilde öğrenmiş ve bu durum tüm sınıflandırma metriklerinde belirgin iyileşmeler sağlamıştır.

ROUGE ve semantik benzerlik skorlarında gözlenen yüksek artışlar ise modelin yalnızca doğru sınıflandırma yapmakla kalmadığını, aynı zamanda güvenlik açıklarına ilişkin açıklamaları referans cevaplara daha yakın biçimde üretebildiğini göstermektedir. Bu sonuçlar, BigVul veri setinin güvenlik açığı farkındalığı kazandırmada oldukça etkili olduğunu ve önerilen ince ayar yaklaşımının güvenlik odaklı görevlerde önemli kazanımlar sağlayabildiğini ortaya koymaktadır.

6.2. SecureCode-Web Deney Sonuçları

SecureCode-Web veri seti modelin OWASP odaklı güvenli kod analizi ve zafiyet analizi yeteneklerini değerlendirmektedir. Tablo 6.2’de temel model ve ince ayar işleminden sonra modelin gösterdiği performans gösterilmiştir.

Tablo 6.2 SecureCode-Web veri seti ile yapılan değerlendirmenin sonuçları

Metrik	Temel Model	İnce Ayarlı Model	Değişim
<i>Doğruluk</i>	0.8913	0.8043	-9.8%
<i>F1-Skor</i>	0.9402	0.8851	-5.9%
<i>Kesinlik</i>	0.9593	0.9720	+1.3%

<i>Duyarlılık</i>	0.9219	0.8125	-11.9%
<i>ROUGE-1</i>	0.2895	0.2679	-7.5%
<i>ROUGE-L</i>	0.1388	0.1305	-6.0%
<i>Semantik Benzerlik</i>	0.6019	0.6231	+3.5%

BigVul veri setinin aksine, SecureCode-Web üzerinde ince ayar işleminin tüm metriklerde iyileşme sağlamadığı görülmektedir. Özellikle doğruluk, F1-Skoru ve duyarlılık değerlerinde belirli düzeyde düşüş meydana gelmiştir. Bununla birlikte kesinlik değerinin artması, modelin bir güvenlik açığı tespit ettiğinde bunu daha yüksek doğrulukla gerçekleştirdiğini göstermektedir.

SecureCode-Web veri setinde doğruluk, duyarlılık ve F1-Skoru değerlerinde düşüş gözlenmesine rağmen kesinlik değerinin artması dikkat çekicidir. Bu durum, ince ayar sonrasında modelin güvenlik açığı tespiti yaparken daha seçici davranmaya başladığını göstermektedir. Başka bir ifadeyle model daha az sayıda güvenlik açığı işaretlemekte, ancak işaretlediği örneklerde daha yüksek doğruluk elde etmektedir. Bu nedenle yanlış pozitif oranlarında azalma sağlanırken bazı gerçek güvenlik açıklarının gözden kaçırılması duyarlılık değerinin düşmesine neden olmuştur.

SecureCode-Web veri setinin görece küçük hacimli olması ve yüksek seviyeli güvenli kodlama senaryolarına odaklanması da bu sonuçları açıklayan önemli faktörlerden biridir. Eğitim sırasında BigVul ve Fenrir-v2.1 gibi veri setlerinin baskın etkisi, modelin web uygulaması güvenliği özelindeki bazı örüntüleri yeterince genelleylememesine yol açmış olabilir. Buna rağmen semantik benzerlik skorundaki artış, modelin ürettiği açıklamaların içerik kalitesini koruduğunu ve güvenlik bağlamında daha tutarlı yanıtlar verdiğini göstermektedir.

6.3. Fenrir-v2.1 Deney Sonuçları

Fenrir-v2.1 veri seti modelin siber güvenlik alanında sohbet yeteneklerini ve talimat takibinin performansını ölçer. Tablo 6.3'te modelin gösterdiği performans sonuçları gösterilmektedir.

Tablo 6.3 Fenrir-v2.1 veri seti ile yapılan değerlendirilmenin sonuçları

<i>Metrik</i>	<i>Temel Model</i>	<i>İnce Ayarlı Model</i>	<i>Değişim</i>
<i>Doğruluk</i>	0.6627	0.7357	+11.0%
<i>F1-Skor</i>	0.7768	0.8354	+7.5%
<i>Kesinlik</i>	0.8699	0.8716	+0.2%

<i>Duyarlılık</i>	0.7017	0.8021	+14.3%
<i>ROUGE-1</i>	0.2769	0.3559	+28.5%
<i>ROUGE-L</i>	0.1305	0.1693	+29.7%
<i>Semantik Benzerlik</i>	0.6982	0.8293	+18.8%

Sonuçlar ince ayar işleminin modelin siber güvenlik odaklı diyalog yeteneklerini geliştirdiğini göstermektedir. Özellikle duyarlılık değerinin yaklaşık %14 oranında artması, modelin güvenlikle ilgili içerikleri daha başarılı şekilde tespit edebildiğini ortaya koymaktadır.

Fenrir-v2.1 veri seti üzerinde elde edilen sonuçlar, ince ayar sürecinin modelin siber güvenlik alanındaki muhakeme ve talimat takip yeteneklerini geliştirdiğini göstermektedir. Özellikle duyarlılık değerindeki artış, modelin güvenlikle ilgili kavramları ve tehdit senaryolarını daha başarılı şekilde tanıyabildiğini ortaya koymaktadır. Veri setinin büyük hacmi ve zengin içerik çeşitliliği, modelin yalnızca belirli güvenlik açıklarını değil, aynı zamanda tehdit analizi, saldırı teknikleri ve savunma mekanizmaları gibi daha geniş siber güvenlik konularını öğrenmesine katkı sağlamıştır.

ROUGE ve semantik benzerlik skorlarındaki iyileşmeler, modelin referans cevapların yapısını ve anlamını daha başarılı biçimde yakalayabildiğini göstermektedir. Bu durum, Fenrir-v2.1 veri setinin modele alan bilgisi kazandırmada önemli rol oynadığını ve güvenlik odaklı diyalog sistemleri geliştirilmesinde etkili bir kaynak olduğunu ortaya koymaktadır.

6.4. Karşılaştırma

Temel model ile ince ayarlı model karşılaştırıldığında, önerilen LoRA tabanlı ince ayar yaklaşımının veri setine bağlı olarak farklı seviyelerde performans kazanımları sağladığı görülmektedir.

En belirgin iyileşme BigVul veri setinde elde edilmiştir. Temel modelin zafiyet tespit görevlerinde yetersiz kaldığı görülürken, ince ayarlı model yüksek doğruluk, yüksek F1-Skoru ve yüksek semantik benzerlik değerleri elde ederek zafiyet analizi konusunda önemli ölçüde uzmanlaşmıştır. Bu durum, BigVul veri setinin modelin güvenlik açığı farkındalığını geliştirmede kritik rol oynadığını göstermektedir.

Fenrir-v2.1 veri setinde de ince ayarlı modelin tüm temel metriklerde daha başarılı sonuçlar ürettiği görülmektedir. Özellikle duyarlılık ve semantik benzerlik skorlarındaki artışlar, modelin siber güvenlik alanındaki talimatları daha iyi yorumlayabildiğini ve daha anlamlı cevaplar üretebildiğini göstermektedir.

SecureCode-Web veri setinde ise farklı bir tablo ortaya çıkmıştır. Kesinlik değeriindeki artışa rağmen doğruluk, F1-Skoru ve duyarlılık metriklerinde düşüş gözlemlenmiştir. Bunun temel nedenlerinden biri veri setinin görece küçük olması ve içerdği güvenli kodlama senaryolarının oldukça spesifik yapıda bulunmasıdır. Buna rağmen semantik benzerlik skorunun yükselmesi, modelin ürettiği açıklamaların anlamsal kalitesini koruduğunu göstermektedir

Genel olarak değerlendirildiğinde, önerilen ince ayar yaklaşımı temel modeli güvenlik açıklarını analiz edebilen, güvenli kodlama prensiplerini yorumlayabilen ve siber güvenlik alanında daha tutarlı cevaplar üretebilen uzmanlaşmış bir modele dönüştürmüştür. Elde edilen sonuçlar, farklı karakteristiklere sahip veri setlerinin birlikte kullanılmasının siber güvenlik odaklı büyük dil modellerinin geliştirilmesinde etkili bir yöntem olduğunu göstermektedir.

KAYNAKÇA

- [1] Y. Chen, Z. Ding, L. Alowain, X. Chen, and D. Wagner, "DiverseVul: A New Vulnerable Source Code Dataset for Deep Learning Based Vulnerability Detection," arXiv preprint arXiv:2304.00409, Apr. 2023.
- [2] Dubniczky, R. A., Horvát, K. Z., Bisztray, T., Ferrag, M. A., Cordeiro, L., & Tihanyi, N. (2025). CASTLE: Benchmarking Dataset for Static Code Analyzers and LLMs towards CWE Detection. In The 19th International Symposium on Theoretical Aspects of Software Engineering (pp. 253–272) https://doi.org/10.1007/978-3-031-98208-8_15
- [3] H. Pearce, B. Ahmad, B. Tan, B. Dolan-Gavitt and R. Karri, "Asleep at the Keyboard? Assessing the Security of GitHub Copilot's Code Contributions," 2022 IEEE Symposium on Security and Privacy (SP), San Francisco, CA, USA, 2022, pp. 754-768, doi: 10.1109/SP46214.2022.9833571.
- [4] Michael Fu and Chakkrit Tantithamthavorn. 2022. LineVul: a transformer-based line-level vulnerability prediction. In Proceedings of the 19th International Conference on Mining Software Repositories (MSR '22). Association for Computing Machinery, New York, NY, USA, 608–620. <https://doi.org/10.1145/3524842.3528452>
- [5] E. Aghaei, X. Niu, W. G. Shadid, and E. Al-Shaer, "SecureBERT: A Domain-Specific Language Model for Cybersecurity," in SecureComm 2022: Security and Privacy in Communication Networks, Lecture Notes of the Institute for Computer Sciences, Social Informatics and Telecommunications Engineering (LNICST), vol. 450, pp. 39–56, 2022.
- [6] E. J. Hu, Y. Shen, P. Wallis, Z. Allen-Zhu, Y. Li, S. Wang, L. Wang, and W. Chen, "LoRA: Low-Rank Adaptation of Large Language Models," arXiv preprint arXiv:2106.09685, 2021.
- [7] Alghawazi, M., Alghazzawi, D., & Alarifi, S. (2022). Detection of SQL Injection Attack Using Machine Learning Techniques: A Systematic Literature Review. Journal of Cybersecurity and Privacy, 2(4), 764-777.
- [8] Jingxuan He and Martin Vechev. 2023. Large Language Models for Code: Security Hardening and Adversarial Testing. In Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security (CCS '23). Association for Computing Machinery, New York, NY, USA, 1865–1879. <https://doi.org/10.1145/3576915.3623175>